

Standard AI-800-74

Liability Allocation for Autonomous Code Generation and Deployment

Joint Directive of the Cybersecurity and Infrastructure Security Agency (CISA) and the Federal Trade Commission (FTC)

Phase-Advancement Audit administered by the National Institute of Standards and Technology (NIST)

1 Purpose and Scope

This Standard establishes the technical and legal thresholds for allocating liability when applications generated, packaged, or deployed by Autonomous Deployment Agents (ADAs) introduce critical vulnerabilities, data breaches, or supply-chain compromises into live production environments. It displaces any reliance on 47 U.S.C. §230 immunity for harms arising from a Covered Provider’s own generative systems where the Provider exercises material default-setting authority over the deployed artifact. It applies to any **Covered Provider** that generates or executes code in a runtime environment, or exercises agentic control over production infrastructure on behalf of an end user.

2 Core Definitions

- **Autonomous Deployment Agent (ADA):** An AI system generating or executing code based on non-deterministic natural-language prompts.
- **Covered Provider:** A person or entity deploying or operating an ADA. The mere public distribution of foundational model weights, without providing an integrated execution environment, does not constitute a Covered Provider. A person that distributes or endorses (including by name, default configuration, or reference documentation) a toolkit, adapter, or integration that couples those weights to a productized or semi-productized **Covered Deployment** shall be a Covered Provider with respect to deployments using the endorsed or coupled tooling, notwithstanding separate distribution of the weights.
- **Covered Deployment:** Any execution by an ADA affecting public data stores, PII, or production environments.
- **Attested Generation:** A deployment where the Provider’s integrated verification layer performs and represents the successful completion of security analysis, dependency provenance, secret scanning, and **functional correctness testing** (generating and executing deterministic, synthetic unit tests to simulate unauthorized access and confirm negative responses).
- **Unattested Generation (“As-Is”):** A deployment where the Provider expressly disclaims technical warranties, requiring the end user to assume verification responsibility.
- **Constructive Attestation:** When an ADA or its user interface (including but not limited to natural-language assurances, badges, checkmarks, “ready to deploy” labels, or similar user-interface signals) affirms to the user, prior to deployment, that a generated artifact is safe, secure, or free of identifiable vulnerabilities, without a contemporaneous, equally prominent Unattested disclaimer in the same workflow step.
- **Default Configuration:** Any property of a generated artifact the ADA sets absent an explicit, informed user override, including without limitation access policies (e.g., row-level security), authentication scaffolds, secret placement, and development versus production data-store linkage.
- **Non-Expert End User:** A user reasonably understood to lack professional training to evaluate default configurations (evidenced by marketing claims or UX design).

3 The Attestation–Liability Boundary

Liability for damages arising from a Covered Deployment is allocated as follows:

3.1 Attested Track & Constructive Attestation — Provider Liability

Trigger: The Provider elects the Attested track, **OR** the ADA provides a Constructive Attestation of security.

Allocation: Strict liability falls on the Covered Provider for damages caused by any vulnerability the verification layer was capable of detecting, or that contradicts the ADA’s Constructive Attestation.

Operational Requirement: Providers must maintain, for not less than seven (7) years, cryptographic logs of (i) every integrated security scan associated with the deployment hash and (ii) the user–ADA conversational session, up to the moment of commit or deploy, that immediately preceded the Covered Deployment, stored in a privacy-preserving form (e.g., encrypted at rest, redactable in accordance with applicable trade-secret and privacy law) sufficient to support enforcement of this Standard and the Constructive Attestation rule.

3.2 Unattested Track — Deployer Liability, Subject to Carve-Outs

Trigger: The Provider expressly elects the Unattested track, or the end user explicitly bypasses verification warnings via cryptographic acknowledgment (§6).

Allocation: Liability falls on the end user as deployer, deemed to have adopted the artifact as their own publication.

Carve-outs (Provider remains liable): (a) ADA provided Constructive Attestation; (b) the user is a Non-Expert End User (§5); (c) Provider failed to produce telemetry (§6); or (d) Provider is restricted from offering Unattested tracks by their Phase-Advancement Tier (§4).

3.3 Third-Party ASA Safe Harbor

A deployer liable under §3.2 may limit liability by routing the artifact through a certified Automated Security Audit (ASA) prior to deployment. If the certified ASA fails to detect the vulnerability, fault is evaluated under standard third-party-auditor frameworks.

4 Phase-Advancement Audit & Tiered Duties

NIST shall conduct an annual Phase-Advancement Audit assigning each Covered Provider a Tier (0–3) based on a weighted index of capability, user-base sophistication, default-security posture, incident rate, harm severity, market concentration, and disclosure responsiveness.

- **Tier 0 & 1 (Baseline):** Providers may offer Attested or Unattested tracks. Tier 1 must enforce default-on access controls, environment separation, and require a hard-halt cryptographic acknowledgment before Unattested deployments reach a live runtime.
- **Tier 2 (High-Risk): No Tier 2 Provider may offer the Unattested track** to a Non-Expert End User. Non-expert users are limited to the Attested track and required safeguards. Provisioning Unattested deployment to a Non-Expert End User is a stand-alone violation. Otherwise, Tier 2 Providers must offer a third-party ASA option, require human-in-the-loop confirmation for production writes, and file an annual **Crumple-Zone Impact Statement** detailing every workflow point relying on human-operator safeguards.
- **Tier 3 (Critical):** Unattested track is universally unavailable except to verified enterprise customers under contract. Requires mandatory per-session kill-switches and public posting of the Crumple-Zone Impact Statement.
- **Exception to Advancement:** A proactive written disclosure to CISA within 24 hours of a Covered Provider's discovery of a material incident, and *before* public or third-party reporting of the same facts, precludes automatic *tier advancement* for that *single* incident as the qualifying event under the Phase-Advancement decision rule. The underlying incident, once disclosed, *remains* in the provider's M4, M5, and M7 record for the weighted index. This exception does not limit liability, civil investigation, or non-tier sanctions.

5 Non-Expert End User Carve-Out

A Covered Provider shall not transfer liability to a Non-Expert End User by means of terms-of-service, click-through disclaimers, or cryptographic acknowledgments for harms proximately caused by a Default Configuration the user could not reasonably evaluate. Any such transfer is void as a matter of law. The FTC may treat as a deceptive trade practice any marketing claim representing artifacts as “production-ready” to Non-Expert audiences when the Provider's default-security posture is deficient.

6 Cryptographic Deployment Signatures & Telemetry

Every Covered Deployment must produce an immutable Cryptographic Deployment Signature recording the hash, Provider Tier, track election, verification outputs, and user-acknowledgment status.

Hard Halt & Acknowledgment: Attempting an Unattested deployment must trigger a hard halt, requiring the end user to execute a cryptographically signed acknowledgment of security responsibility (void for Non-Expert Users). Signatures must be accessible to regulators; failure of a Provider to produce them defaults liability to the Provider.

7 Enforcement & Coordinated-Disclosure SLA

Violations are enforceable by CISA (technical duties/telemetry) and the FTC (consumer deception/marketing claims). Providers must maintain a 45-day coordinated vulnerability disclosure SLA; disputing a report without remediation preserves Provider liability under §3.